MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 075 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FOLLOW-UP · CMMC REFORM

The CMMC Review Found the Cost Is the Controls, Not the Certificate

DoD's own summary of CMMC reform comments puts the cost in NIST 800-171, not certification. What the task force options change for a small contractor.

BY **MAXINE** READING TIME · 6 MIN CMMC · CMMC-REFORM-TASK-FORCE · NIST-800-171 · CUI · POAM

Yesterday, November 10, was the day the Department of War meant to start writing third-party CMMC certification into contracts. It passed quietly, because on July 13 the Department suspended Phase 2 and asked industry to explain what the program was costing. Industry answered. And the answer, now that a summary of it has surfaced, does not say what the suspension assumed it would say: the expensive part of CMMC was never the certificate. It was the 110 security requirements underneath it, which no pause has touched.

That matters more to a 20-person shop than to anyone else in the defense industrial base, because it tells you where the next year of money should go. When MacZine last tracked this story, in the class deviation timeline of September 15, the task force's recommendations were due and unseen. They are still unpublished. What changed between October 26 and 27 is that Federal News Network obtained DoD's summary of the request-for-information responses and the task force's options, and reported both in detail.

FIELD COPY
ISSUE Nº 075
CMMC

$47,000

AVERAGE COST OF CMMC COMPLIANCE EXCLUDING THE NIST SP 800-171 CONTROLS, PER DOD'S ANALYSIS OF RFI RESPONSES AS REPORTED BY FEDERAL NEWS NETWORK

The case for the pause, and what the comments did to it

Start with the Department's argument, stated fairly. CIO Kirsten Davies gave four reasons for the suspension: compliance costs prohibitive for small businesses, an assessment model she called a "check-the-box, point-in-time view" of how a company handles sensitive data, a shortage of third-party assessors, and a tangle of regulatory timelines. Those are serious claims, and the RFI was the instrument meant to test them.

Here is what came back, per the reporting. DoD reviewed 997 responses, 509 of them from the industrial base itself. Its own analysis put the average cost of CMMC compliance, excluding the NIST SP 800-171 controls, at about $47,000. Third-party assessment fees ranked only fifth among cost drivers, and DoD said assessment prices fell over the first year. The capacity argument fared no better: 2,433 companies held Level 2 certification by September, roughly five times the Department's first-year estimate, and one industry source told the outlet that demand never exceeded half of available assessor capacity during Phase 1.

509

OF 997 REVIEWED RFI RESPONSES CAME FROM THE DEFENSE INDUSTRIAL BASE; THE REST CAME FROM VENDORS, CONSULTANTS AND THE ASSESSMENT ECOSYSTEM

2,433

COMPANIES HOLDING LEVEL 2 CERTIFICATION AS OF SEPTEMBER 2026, ABOUT FIVE TIMES DOD'S ESTIMATE FOR THE FIRST TWELVE MONTHS

What respondents did name as their heaviest costs were licensing, enclave hardware, documentation, evidence packages, specialized staff, and inconsistent CUI marking across DoD. The system security plan topped the list of overhead burdens; FIPS-validated encryption came second. Hunton partner Eric Crusius put the misdiagnosis in a sentence: "The cost of program is blamed on certification instead of underlying certification controls."

Suspending the certificate did not suspend the bill. The bill was never the certificate's.

None of those cost lines moved on July 13. DFARS 252.204-7012 still binds the Rev 2 controls into your contracts, Level 2 (Self) still requires a current SPRS score, and the SSP that respondents ranked as their biggest overhead is the same document an assessor, a prime, or DCMA will ask for. A small contractor who read the pause as a reason to defer security spending was deferring the wrong line item.

The options, sorted by what they do to your budget

The task force, a group of about 20 led from the CIO's DIB operations office, sorted its ideas into changes the CIO could make without rulemaking, harder changes that may need rulemaking, and ideas outside the CIO's authority. It attached timelines. Read them not as a forecast but as a list of decisions you can make before DoD makes its own.

A narrower Phase 2 restart within 90 days. The summary does not say who would be in the narrower population, and nothing has been approved. If you had a C3PAO assessment scheduled, the conservative move is to keep it: as our September reading of the deviation found, a Final Level 2 (C3PAO) status remains valid and satisfies a lower requirement, and you will not know whether you are in the restart group until a solicitation tells you.

A 270-day POA&M window. This is the option small firms will want most and should plan on least. The summary itself says it would require rulemaking. As of November 2, 32 CFR 170.21 still reads as it did: a conditional status needs a score of at least 0.8 of the maximum, and a closeout assessment within 180 days or the status expires. Build remediation schedules on the rule in the eCFR, which our POA&M piece walks through, not on the rule in a briefing.

Finishing the move to NIST SP 800-171 Rev 3. The summary recommends it, and a second revision to reflect a "new direction" the documents do not describe. Rev 3 has been on hold since Davies took office in December, and DoD contracts still score against Rev 2. An industry source warned the outlet that the delay pushes contractors toward maintaining two standards. For a small shop the answer is the one in our Rev 2 versus Rev 3 piece: implement and score Rev 2, keep a crosswalk, and do not rewrite your SSP for a baseline your contracts do not yet name.

◆ WHERE THE NUMBERS COME FROM

The Department has not published the RFI summary or the task force report. Every figure here comes from Federal News Network's two-part investigation of October 26 and 27, 2026, which obtained the documents. DoD declined to comment on the results after the outlet sent it 15 specific questions. Treat the options as reported options, not policy, until a memo or a revision of class deviation 2026-O0025 says otherwise.

ISO 27001 credit within six months. Useful only if you already hold the certificate. If you do, start tagging which evidence serves both programs now, so a reciprocity rule finds a package rather than a project.

Machine-readable criteria, STIG-style templates, grants and free tools, a year or more out. All of it welcome, some of it subject to funding. None of it pays this year's licensing invoice.

The one lever a small firm already holds

Buried in the six-month tier is the option with the most money in it: reduce the volume of CUI that flows to primes and subcontractors in the first place, through training, marking tools, classification guides, and virtual-desktop or hardcopy handling. DoD told the outlet that a planned FAR rule, which would add a standard form describing the CUI to be shared and safeguarded, has the greatest potential to narrow the population subject to NIST 800-171. That rule is the one MacZine examined in the FAR CUI piece. The Defense Acquisition Regulations System's open FAR-case list dated October 30 shows the old FAR CUI case on hold since August 7, to be carried by the overhaul rule published June 23 at 91 FR 37550. No final rule has issued.

You do not have to wait for it. Every CUI-marked file in your environment expands the boundary you pay to protect, and much of it arrives by habit rather than need. Pull the last twelve months of marked material your primes sent you and ask, file by file, whether the work required it. Where marking looks wrong, 32 CFR 2002.50 lets an authorized holder who believes a designation is improper challenge it by notifying the disseminating agency; a subcontractor will in practice raise it through the prime that sent the file. Where the work did not need the file, ask for it to stop coming. Our pieces on what actually makes a file CUI and on CUI sprawl cover the mechanics. A firm that halves what it holds has not lowered its standard; it has shrunk the thing the standard applies to, and the enclave, the licenses and the evidence load shrink with it.

That is also the honest reading of the review. The Department set out to ask whether certification costs too much, and the respondents answered that protecting CUI does, and that too much CUI is going to too many people. Whatever the restart looks like, and whenever it comes, the contractor that spent this fall reducing what it holds will face the smaller bill. The next dated document worth watching is a quiet one: DoD's open DFARS-case list shows the final rule for the 2020 interim NIST SP 800-171 assessment requirements, case 2022-D017, still being drafted, with its report now due December 9. ◆